Si on fuzz RtRebox.Rtb on obtiendra aucun résultat car il n'y a pas de sous domaine publique pour un domaine privé (lui même seulement accessible via "réduire" ou plutôt enregistrement local dans /etc/Hosts). Comme on a ajouter que le domaine principal dans /etc/Hosts, ffuf n'y trouve pas de sous domaine interroge le DNS publique et naturellement ne trouve rien. disons sous-domaine= mot vhost règle d'or un de Nous allons donc fuzzer les vhost (sous-domaines privés bien pas vraiment) grâce à l'en-tête Host, le but sera de trouver pour lequel la reponse du serveur aura une taille différente et ainsi trouver un vhost valide...

```
Agentpathogene@parrot ~$ ffuf -w /path/to/subdomain.txt -u http://academy.Rtb:Port/ -H 'Host: FUZZ.academy.Rtb'
```

-fs 154 : pour skipper les requete d'une taille précise (ici 154)
d'autres options de filtrages sont disponibles n'hésiter pas à fouiller l'aide des outils et les tester en labos...
- mc 200,302 : c'est le match code il n'affiche que les requetes qui renvoient les codes sélectionnés ici 200 et 302
- mr "Succes" : affiche uniquement les pages contenant le regex spécifié...

Fuzzing de Paramètres:

Un parametre (dans une URL) est une variable que l'on transmet à une page web pour modifier son comportement ou lui donner une instruction spécifique (Exemple: accademy.php?hasp=fsr) - (Pour les parametre GET)

```
Agentpathogene@Parrot ~$ ffuf -w /Web-Content/burp-parameter.name.txt -u http://academy.Rtb/admin/admin.php?FUZZ=Key -fs xxx
```

La principale différence entre les requetes POST et GET est que le parametre n'est pas simplement transmis dans l'URL d'après un ? mais dans le champ data le request body quoi...
Pour fuzzer le champ data on va utiliser l'option -d et bien sur on spécifie la méthode POST avec l'option -X POST
NB: en php le content-type des données "POST" ne peux être que "application/x-www-form-urlencoded" on peu donc aussi pour l'exemple le définir avec -H pour Header

```
Agentpathogene@parrot ~$ ffuf -w /path/to/burp-parameter.txt -u http://academy.Rtb/admin.php -X POST -d 'FUZZ=Key' -H 'Content-Type: application/x-www-form-urlencoded' -fs xxx
```

Une fois le paramètre trouvé on peu faire un curl "personalisé"

```
Agentpathogene@parrot ~$ curl http://academy.Rtb/admin.php -X POST -d 'parametretrouve=Key' -H 'Content-Type: application/x-www-form-urlencoded'
```

Une fois un parametre trouvé on peux vouloir trouvé sa valeur "imaginons que l'on a une IDOR ou manipuler l'id donne accès aux données d'un autre utilisateur on peu vouloir automatiser l'attaque en fuzzant les valeurs. Le format de l'id peu être formaté personalisé ou séquentielle, le mieux reste donc un petit script bash pour generer une wordlist adéquate un exemple ci dessous avec des nombres de 1 à 1000.

```
Agentpathogene@parrot ~$ for i in $(seq 1 1000); do echo $i >> nb.txt; done
```

Ensuite plus qu'à bien placer son FUZZ:

```
Agentpathogene@parrot ~$ ffuf -w /path/to/nb.txt -u http://admin.Rtb/admin.php?user=FUZZ -fs xxx
```